

Principles of Computer Security, Sixth Edition

Chapter 11 Solutions

Key Terms Quiz

1. Kerberos
2. Role-based access control (RBAC)
3. Transitive trust
4. Mandatory access control (MAC)
5. Single sign-on (SSO)
6. HMAC-based One-Time Password (HOTP) or Time-based One-Time Password (TOTP)
7. False positive. It's telling you there's something wrong (not an authorized fingerprint) when there isn't really anything wrong (you are in fact authorized). This is a false positive; just like when you scan a system and it tells you there are issues when there really aren't any.
8. mutual authentication
9. Attribute-based access control (ABAC)
10. basic authentication

Multiple-Choice Quiz

1. **D.** Authentication is commonly performed with passwords (something you know), tokens (something you have), and biometrics (such as fingerprints).
2. **A.** Your supervisor just defined the *false rejection rate (FRR)* for your system, which is the level of false positives, or rejections, that are going to be allowed in the system. In this case, your supervisor is willing to accept one false rejection for every 50 attempts. See comments earlier in the chapter on false positives, false negatives, FAR, and FRR.
3. **D.** Kerberos uses ticket-granting servers to manage the issuance of tickets granting various permissions on the system.
4. **A.** RADIUS has been officially assigned UDP port 1812 for RADIUS Authentication and port 1813 for RADIUS Accounting by the Internet Assigned Number Authority (IANA).

However, previously, ports 1645 (authentication) and 1646 (accounting) were used unofficially and became the default ports assigned by many RADIUS client/server implementations of the time. The tradition of using 1645 and 1646 for backward compatibility continues to this day. For this reason, many RADIUS server implementations monitor both sets of UDP ports for RADIUS requests. Microsoft RADIUS servers default to 1812 and 1813, but Cisco devices default to the traditional 1645 and 1646 ports.

5. **C.** Under mandatory access control (MAC), each piece of information and every system resource (files, devices, networks, and so on) is labeled with its sensitivity level.
6. **C.** The *Time-based One-Time Password (TOTP)* algorithm is a specific implementation of an HOTP that uses a secret key with a current timestamp to generate a one-time password.
7. **A.** OpenID and OAuth are typically used together, yet have different purposes. OpenID is used for authentication, whereas OAuth is used for authorization.
8. **B.** Kerberos works using tickets. A ticket-granting ticket is one type of ticket obtained from the authentication server.
9. **D.** PPTP uses TCP port 1723 to establish communications, so this port must be open across a firewall for PPTP to function correctly.
10. **D.** L2TP uses UDP port 1701 to establish communications, so this port must be open across a firewall for L2TP to function correctly.

Essay Quiz

1. This answer should include a basic discussion of Linux file permissions. For students who are not familiar with Linux, this chapter contained some basic information, such as the following:
 - Linux permissions are usually divided into three main parts:
 - Owner permissions (read, write, and execute)
 - Group permissions (read, write, and execute)
 - World permissions (read, write, and execute)

- Linux permissions are usually displayed as a string of nine characters (rwx rwx rwx), with owner permissions in the first three characters, group permissions in the next three, and world permissions in the final three.
2. *Authentication* is the process by which a user confirms their identity by some means. It answers only the question of whether the person is who they claimed to be when the identification process was completed. *Authorization*, on the other hand, grants specific permissions based on the privileges held by the account that is authenticated. Generally, you must authenticate before you are authorized to perform any actions; otherwise, any authorization would be for an unknown user.